Relazione Tecnica: Vulnerabilità Web su DVWA

Corrado Vaccarecci
Laboratorio: Cybersecurity - Sfruttamento Vulnerabilità Web
Target: Metasploitable 2 (DVWA) - IP: 192.168.50.101
Livello di Sicurezza: LOW

1. Configurazione del Laboratorio

Il laboratorio è stato configurato utilizzando una rete interna isolata. La comunicazione tra la macchina attaccante (**Kali Linux**) e la macchina vittima (**DVWA**) è stata verificata tramite il comando ping. Una volta stabilita la connessione, è stato effettuato l'accesso alla piattaforma DVWA tramite browser e il livello di sicurezza è stato impostato su **LOW** per permettere l'analisi delle vulnerabilità base.

2. Sfruttamento Vulnerabilità XSS (Reflected)

Descrizione

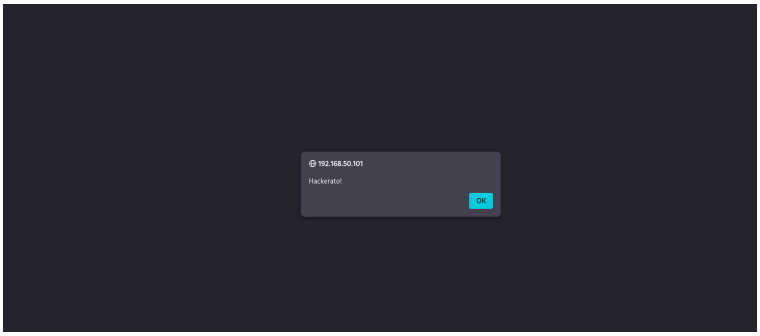
Il **Cross-Site Scripting (XSS)** di tipo Reflected si verifica quando un'applicazione web include dati forniti dall'utente in una pagina inviata al browser, senza che questi siano stati opportunamente verificati o codificati.

Esecuzione

Nella sezione "XSS (Reflected)", è stato inserito un frammento di codice JavaScript nel campo di input. L'applicazione, non filtrando i caratteri speciali, ha eseguito il codice direttamente nel browser.
Payload utilizzato: <script>alert('Hackerato!')</script>

Risultato

Il browser ha interpretato il testo non come una stringa, ma come un comando eseguibile, mostrando un pop-up di avviso.



3. Sfruttamento Vulnerabilità SQL Injection

Descrizione

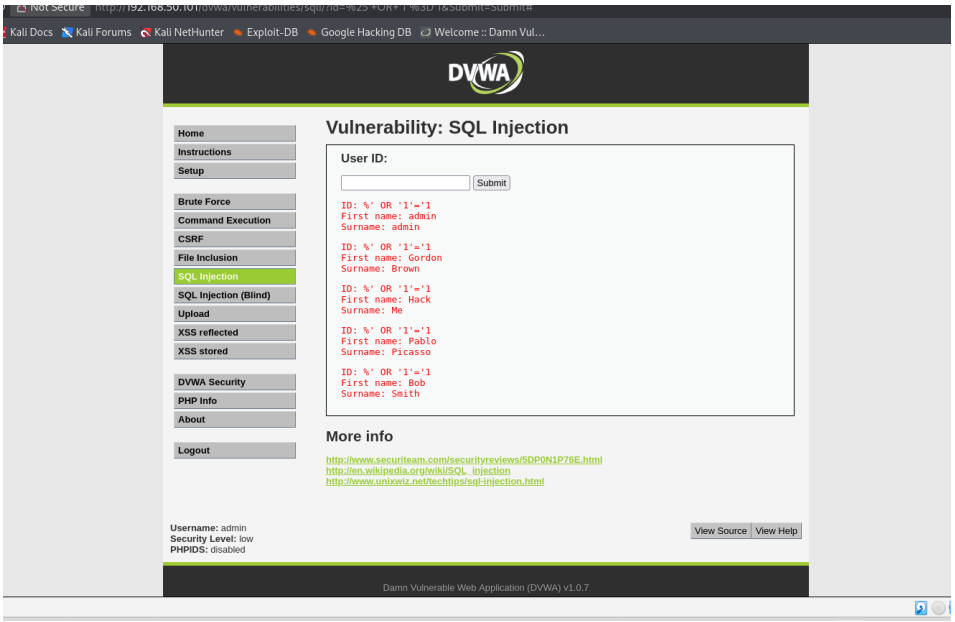
La **SQL Injection** è una vulnerabilità che permette a un attaccante di interferire con le query che un'applicazione effettua sul proprio database. In questo caso, è stata utilizzata una tecnica "Non-Blind" per estrarre dati visibili direttamente sulla pagina.

Esecuzione

Nel campo "User ID" è stata inserita una stringa contenente un operatore logico OR seguito da una condizione sempre vera ('1'='1'). Questo ha permesso di bypassare il filtro dell'ID utente, "ingannando" il database e costringendolo a mostrare ogni record presente nella tabella degli utenti.
Payload utilizzato: %' OR '1'='1

Risultato

L'applicazione ha restituito l'elenco completo degli utenti presenti nel database, inclusi nomi e cognomi di account amministrativi, violando la riservatezza dei dati.



4. Conclusioni

Le prove effettuate dimostrano che la mancata validazione degli input lato server espone l'applicazione a rischi critici.

Per mitigare l'XSS: è necessario implementare l'encoding dei caratteri speciali in uscita.

Per mitigare la SQL Injection: è fondamentale l'adozione di "Prepared Statements" (query parametrizzate) che impediscono l'esecuzione di codice SQL non autorizzato.